

MFA, SSO & Federation

MFA: Defense Against the Password

The (now old) "password" is nearly useless alone. MFA adds a second factor. MITRE ATT&CK maps credential-theft attacks; MFA blocks a huge share:

Phishing – attacker has your password but not your second factor

Credential stuffing – same

Pass-the-hash/cookies – some MFA blocks these too

MFA Methods Ranked

Factor	Security	Notes
OTP app (TOTP)	Medium	Phishable in real-time relay; SIM-independent
Push prompting	Medium	MFA fatigue – user approves anyway
SMS	Weak	SIM swap + interception
WebAuthn/passkeys	Strong	Resistant to phishing; cryptographically bound to the site
Hardware key (FIDO2)	Strong	Best-in-class

SSO: One Login to Rule Them All

Single Sign-On lets one identity server act as the gate for many apps:

User authenticates once (often MFA)

Then every app trusts that session

Benefits: fewer passwords to phish, centralized policy, centralized logging. **Risk:** one compromised SSO session = many apps. Hence: strong MFA + session monitoring are mandatory.

Federation Protocols (The Alphabet Soup)

Protocol	Used By	Type
SAML 2.0	Many enterprise apps	XML assertions
OAuth 2.0	Authorization ONLY (scoped access)	Tokens
OIDC (on OAuth2)	Modern identity + login	JWT ID tokens

Key flows:

SAML/Web SSO – browser redirects to IdP, IdP returns an assertion (XML), app trusts it

OAuth 2.0 – "are the app ALLOWED to act for the user?" → access token (not identity)

OIDC – OAuth + an ID Token (JWT) that carries the identity claim

The Trust Boundary Danger

Federation = multiple parties trust ONE identity source. Attack surface:

Token theft / replay – steal an assertion/token, reuse elsewhere (mitigate: audience, nonce, short TTL, not in URL)

Badly implemented IdP – weak MFA or no checks

Scope escalation – a token issued for "read email" used for "send email" (OAuth scope confusion)

Session fixation – attacker plants a session ID the victim logs into

Golden rule: every federated app is only as strong as its IdP + its session handling. Secure both.

[← IAM Concepts: Authentication...](#)

[RBAC, ABAC & Authorization Mod...](#)